

Préparation Audits & Questions Jury — PixelStore

Dossier de Préparation aux Audits & Questions du Jury — PixelStore

Date : 15 Juin 2026

Auteur : Matthieu Broquard (Architecte Cloud & DPO)

Destinataires : Équipe Projet PixelStore

Classification : Confidentiel - Interne

1. Executive Summary (Résumé Exécutif)

Ce dossier prépare l'équipe technique de PixelStore aux questions et objections des auditeurs ou du jury de soutenance.

L'analyse de l'architecture déployée met en relief **trois points d'attention critiques** :

1. Une faiblesse d'isolation réseau (le placement des serveurs applicatifs EC2 dans les subnets publics, avec des adresses IP publiques associées).
2. Une opportunité d'optimisation financière (la facturation d'une NAT Gateway à hauteur de 50 €/mois alors qu'elle n'est traversée par aucun trafic).
3. Un défaut de configuration applicative concernant l'en-tête de proxying `ProxyFix` de Flask, qui limite la visibilité des adresses IP clientes réelles.

Ce document fournit des **réponses factuelles et rassurantes** permettant de justifier ces choix comme des étapes transitoires de développement (dette technique acceptée), tout en présentant une cible de production corrigée et budgétisée.

2. Structuration GRC pour l'Audit

A. Gouvernance de l'Administration AWS

L'accès à l'infrastructure s'appuie sur deux piliers de contrôle d'accès :

- **Moindre privilège IAM** : Les instances EC2 portent un rôle IAM restrictif limitant l'accès aux seules ressources nécessaires (Secrets Manager et bucket S3 média).
- **Administration sans agent (SSM)** : Le protocole SSH (port 22) est entièrement désactivé. La maintenance s'effectue via AWS Systems Manager Session Manager, assurant une traçabilité complète des commandes.

B. Gestion des Risques (Analyse des Écarts d'Architecture)

- **Exposition réseau directe des EC2** : Le placement en subnet public avec IP publique expose théoriquement les serveurs. La mitigation repose exclusivement sur le **Security Group** (filtrage sur le port 5000 restreint à l'ALB). La cible consiste à déplacer les EC2 dans les subnets privés.
- **Flux internes non chiffrés** : Le tronçon reliant l'ALB aux instances EC2 s'effectue sur le port 5000 en HTTP clair. La recommandation est de chiffrer ce tronçon interne en production ou de passer par une liaison privée HTTPS.

C. Conformité Réglementaire et Normative

- **RGPD & DPA (Data Processing Agreement)** : Non-conformité identifiée sur l'Article 30 (absence de registre) et l'absence de DPO. La localisation physique à Paris (eu-west-3) assure la conformité de stockage.
 - **Authentification Forte (MFA)** : Non configurée sur les comptes utilisateurs IAM. L'axe correctif est d'appliquer une politique IAM Terraform interdisant toute action de console ou d'API sans authentification double facteur active.
-

3. Plan de Réponse aux Questions du Jury (Tableaux par Thématique)

Thématique 1 : Architecture Réseau & Sécurité AWS

Question Attendue	Risque / Point Technique	Réponse Recommandée pour la Soutenance
Q1. Pourquoi vos serveurs Flask/EC2 sont-ils dans des subnets publics ?	Violation du principe de l'architecture 3-tiers et augmentation de la surface d'attaque.	Admettre la dette technique : « C'est exact. C'est un écart identifié lors de notre audit de sécurité. Les instances possèdent des IP publiques pour faciliter le déploiement en laboratoire, mais la sécurité est maintenue par un Security Group bloquant tout trafic hors port 5000 depuis l'ALB. Notre cible P3 consiste à les déplacer dans nos subnets privés. »
Q2. Pourquoi payez-vous une NAT Gateway si elle n'est pas utilisée ?	Incohérence FinOps (gaspillage de 50 €/mois, soit 33 % du budget).	Proposer l'optimisation financière : « C'est une dette FinOps identifiée. Comme nos EC2 sont publiques, elles sortent directement via l'Internet Gateway (IGW) ; la NAT Gateway tourne donc à vide. En déplaçant les EC2 en subnet privé (cible P3), elles utiliseront cette NAT. Alternativement, nous prévoyons de supprimer la NAT Gateway et de la remplacer par des VPC Endpoints S3/Secrets Manager gratuits/économiques. »
Q3. Comment administrez-vous vos serveurs sans clé SSH ?	Gestion et vol potentiel de clés privées, port 22 ouvert.	Valoriser l'alternative AWS SSM : « Nous avons désactivé SSH (port 22 fermé). Nous utilisons AWS Systems Manager (SSM) Session Manager . L'accès est contrôlé par IAM, ne nécessite aucun port ouvert en entrée, et toutes les commandes de maintenance sont tracées dans CloudTrail. »

Thématique 2 : Gouvernance, GRC & RGPD

Question Attendue	Risque / Point Technique	Réponse Recommandée pour la Soutenance
Q4. Comment justifiez-vous une conformité ISO 27001 de seulement 28 % ?	Faiblesse apparente du programme de sécurité global.	Différencier technique et organisationnel : « Ce score de 1,72/5 intègre des contrôles RH (A.6) et organisationnels (A.5) non applicables à un projet académique (absence de chartes de sécurité SI, de contrats de travail ou de procédures d'embauche). En revanche, notre maturité technique et physique (A.7 et A.8) est optimale grâce au durcissement post-pentest. »
Q5. Votre hébergement à Paris suffit-il à vous rendre conforme au RGPD ?	Confusion entre souveraineté de stockage et obligations juridiques du RGPD.	Reconnaître les écarts réglementaires : « Non. L'hébergement local résout la souveraineté, mais nous devons formaliser notre conformité juridique. Nous avons planifié en phase P2 la désignation d'un DPO (Délégué à la Protection des Données) et la rédaction du registre des activités de traitement (Article 30 du RGPD). »
Q6. Le MFA est-il activé par défaut sur vos comptes utilisateurs AWS ?	Sécurité des accès d'administration IAM.	Préciser la politique AWS et la correction : « AWS impose le MFA par défaut uniquement sur le compte Root. Pour nos utilisateurs IAM (admins/développeurs), il est inactif par défaut dans notre configuration. Notre action corrective consiste à déployer une politique IAM globale dans Terraform interdisant toute action d'API ou de console sans validation MFA. »

Thématique 3 : Méthodologie FAIR

Question Attendue	Risque / Point Technique	Réponse Recommandée pour la Soutenance
Q7. D'où proviennent vos chiffres de pertes financières FAIR ?	Fiabilité de l'estimation des risques financiers.	Détailler la méthode PERT-Beta : « Nos chiffres proviennent d'une simulation de Monte Carlo (10 000 itérations) basée sur la méthode PERT à 3 points. Nous avons estimé les pertes directes (remédiation, perte d'exploitation) et secondaires (notifications CNIL, amendes) en nous basant sur les données réelles du marché des cyberattaques pour les PME de 35 salariés. »

Thématique 4 : Technique Applicative Flask

Question Attendue	Risque / Point Technique	Réponse Recommandée pour la Soutenance
Q8. Pourquoi le ProxyFix configuré avec x_for=1 est-il erroné ?	Masquage de la véritable IP cliente par le double proxying (CWE-348).	Corriger l'architecture de proxying : « Notre architecture comporte deux proxies (Cloudflare + ALB). Avec <code>x_for=1</code> , Flask ne remonte que d'un saut et prend l'IP de Cloudflare pour l'IP du client final. Cela corrompt la journalisation et le rate limiting. Nous devons configurer <code>x_for=2</code> dans <code>app.py</code> pour remonter jusqu'à l'IP réelle du client. »
Q9. Quel est l'impact de la rotation de la SECRET_KEY de Flask ?	Déconnexion massive et perte des paniers d'achat des clients actifs.	Anticiper l'impact métier : « La <code>SECRET_KEY</code> sert à signer les cookies de session. Si nous faisons une rotation (via Terraform et Secrets Manager), toutes les signatures existantes deviennent invalides. Tous les clients actifs seront instantanément déconnectés et perdront leur panier. Cette opération doit être planifiée lors d'une fenêtre de maintenance. »
Q10. Quel est votre mode TLS sur Cloudflare ? Flexible ou Full ?	Absence de chiffrement sur le réseau public d'Internet.	Défendre le mode Full (Strict) : « Nous visons le mode Full (Strict) avec un certificat valide sur notre ALB. Si nous utilisons le mode Flexible, Cloudflare communiquerait en HTTP clair (port 80) avec notre ALB sur Internet, ce qui permettrait l'interception des données malgré le cadenas HTTPS visible chez le client. »